

Co2 - Assessment - 21) Nmap Scan Report Analysis

Introduction:- Nmap (Network Mapper) is a network scanning tool used to discover hosts, open ports, running services, service versions, and operating system details. While it is an essential tool for security professionals, attackers can also use it to identify vulnerable services on a target system.

Scenario:-

Target IP Address 192.168.1.10

Open ports:-

- 22/TCP - SSH
- 80/TCP - HTTP
- 3306/TCP - MySQL

Analysis of Identified Services:-

1. SSH (port 22)

Purpose:- SSH (Secure Shell) provides secure remote access to the server.

Security Risks:-

- Weak or default passwords can be guessed using
- Outdated SSH version may contain vulnerabilities
- Root login over SSH increases security risks.

Possible Attacks

- password brute-force attacks
- credential theft
- Exploitation of vulnerable SSH versions

Security Measures:-

- Use strong password or SSH keys
- Disable root login
- Change the default SSH port (optional)

2. HTTP (port 80)

purpose:- HTTP hosts websites and web applications.

Security Risks:-

- Data transmitted without encryption
- vulnerable web application may allow attacks

Possible Attacks:-

- SQL injection
- Cross-site scripting (XSS)

Security Measures:-

- Replace HTTP with HTTPS
- Install SSL/TLS certificates
- Keep Apache/Nginx updated.

3) MySQL (port 3306)

purpose:- Stores application database

Security Risks:-

- default credentials.
- weak database passwords
- Remote database access.

Possible Attacks:-

- Unauthorized database access
- SQL injection.
- Database escalation.

Security Measure:-

- Disable remote access if unnecessary
- Use strong database passwords
- Remove anonymous users.

2) Gophish Report Analysis

Introduction:- Gophish is a phishing simulating platform used to measure employee's

Report Findings:-

- 40% clicked the phishing link
- 20% entered login credentials

Analysis of Employee Security Weaknesses:-

1. Clicking the phishing link

Weaknesses:-

- Employees failed to verify suspicious email's
- Trusted unknown links
- Ignored warning signs

Security Risks:-

- Malware infection
- Fake login pages
- Credential theft.

2. Entering login Credentials

Weaknesses:-

- Employees could not identify fake login pages.
- poor awareness of credential theft.

Security Risks:-

- Account compromise
- Unauthorized access
- Identity theft.

3. Downloading Malicious Attachments:-

Weaknesses:-

- Employees opened unsafe attachments
- Lack of caution with email attachments.

Security Risks:-

- Malware infection
- Ransomware
- Trojan installation.

Recommended User Awareness Programs:-

- Employees should learn
- Phishing simulation exercises
- Password Awareness
- Incident Reporting.

Email Security Controls:-

- Email Filtering:-
- SPF, DKIM, and DMARC
- Secure Email Gateway
- Attachment Sandboxing

Organizational Policies:-

- Acceptable use policy
- Mandatory security training
- Password policy

3) DNS Zone Transfers (AXFR) Assessment using Dig:-

Introduction:-

The Dig tool is used to query DNS servers and troubleshoot DNS configurations.

The assessment revealed that the DNS server allows DNS Zone Transfer

This exposes:-

- Internal hostnames
- Mail servers
- DNS records
- Network structure

Security Implications:-

Exposure of Internal Information:-

- Internal servers
- Subdomains
- Mail servers
- Backup servers

Network Reconnaissance:-

The DNS records provide attackers with a complete map of the organization's infrastructure.

Possible Attacks

Targeted Attacks

- Web Servers
- Mail Servers
- VPN Servers
- Database Servers
- Phishing
- Vulnerability Scanning
- Brute Force Attacks
- Best Practices to Secure DNS Infrastructure
 - Restrict DNS Access
 - Enable DNSSEC
 - Hide Internal DNS Records
 - Monitor DNS logs
 - Keep DNS Software updated
 - Restrict Recursive queries

Conclusion :- Allowing unrestricted DNS zone transfers (AXFR) exposes valuable network information that attacks can use for reconnaissance and targeted attacks. Restricting AXFR to authorized servers, implementing DNSSEC, using firewalls and ACLs, separating internal and external DNS, and monitoring DNS activity are essential measures to secure the organization's DNS infrastructure.